



Blockchain Security in Decentralized Finance (DeFi)

Emils Bagirovs

Bachelor's thesis

May, 2025

Information and Communications Technology



Bagirovs, Emils

Blockchain Security in Decentralized Finance (DeFi)

Jyväskylä: Jamk University of Applied Sciences, May 2025, 39 pages

Degree Programme in Information and Communications Technology. Bachelor's thesis.

Permission for open access publication: Yes

Language of publication: English

Abstract

This thesis explores the security challenges in decentralized finance (DeFi), a system that uses blockchain technology to provide financial services without traditional banks. DeFi faces serious security risks such as hacking, scams, and technical flaws, which threaten its growth and user trust. The study investigates common vulnerabilities like smart contract errors, flash loan attacks, and rug pulls. These problems allow attackers to steal large amounts of money, as seen in real cases like the DAO hack and AnubisDAO scam. The research uses analysis of existing studies and real-world examples to understand how technical weaknesses, poor governance, and human greed contribute to these attacks. The findings show that current solutions, such as code audits and insurance, are not enough to protect users. Technical flaws in smart contracts, like reentrancy bugs or oracle failures, remain major risks. Flash loan attacks exploit instant borrowing features to manipulate markets, while rug pulls involve developers disappearing with investor funds. The study suggests combining technical improvements with better governance to reduce risks. While DeFi aims to operate without central control, some level of oversight is needed to prevent fraud. Future trends may include advanced monitoring tools, decentralized insurance, and education for users. By improving security practices and fostering trust, DeFi can grow into a reliable alternative to traditional finance while maintaining its innovative spirit.

Keywords/tags (subjects)

Blockchain Security, Decentralized Finance, DeFi, Smart Contracts, Flash Loans, Rug Pulls

Miscellaneous (Confidential information)

No confidential information was disclosed in the thesis.

Contents

1. Introduction	3
1.1. Background and Context of DeFi.....	3
1.2. Problem Statement: Security Challenges in DeFi	4
1.3. Research Objectives and Questions	4
1.4. Significance of the Study	5
2. Literature Review	6
2.1. Overview of Blockchain and DeFi Ecosystems.....	6
2.2. Existing Research on DeFi Vulnerabilities.....	7
2.3. DeFi Attacks (Flash Loans, Smart Contracts, Rug Pulls)	7
2.4. Current Mitigation Strategies and Their Limitations	9
3. Fundamentals of DeFi Systems	10
3.1. Key Components of DeFi (Lending Protocols, DEXs, Stablecoins)	10
3.2. Technical Mechanisms: Smart Contracts, Oracles, Liquidity Pools.....	11
3.3. Economic and Governance Models in DeFi.....	12
3.4. Security as a Core Challenge	13
4. Analysis of DeFi Attack Types.....	14
4.1. Flash Loan Attacks	14
4.1.1. Mechanics of Flash Loans	14
4.1.2. Case Examples.....	15
4.1.3. Exploitation Pathways and Impact	16
4.2. Smart Contract Vulnerabilities	17
4.2.1. Common Flaws (Reentrancy, Integer Overflows, Access Control).....	17
4.2.2. Case Studies	18
4.3. Rug Pulls and Exit Scams	19
4.3.1. Mechanisms of Rug Pulls (Liquidity Removal, Token Minting).....	19
4.3.2. Analysis of DeFi Attack Types: Rug Pulls and Exit Scams – Case Studies	20
4.4. Root Cause Analysis and Lessons Learned	22
5. Proposed Mitigation Strategies.....	23
5.1. Technical Solutions.....	23
5.1.1. Smart Contract Auditing Tools and Best Practices	23
5.1.2. Flash Loan Attack Mitigations (Time Locks, Transaction Limits).....	24
5.1.3. Rug Pull Prevention	25
5.2. Economic and Governance Solutions (DAOs, etc.).....	26

5.2.1. Decentralized Insurance Protocols.....	26
5.2.2. Reputation Systems for DeFi Projects	27
5.3. Compliance and Transparency	28
6. Discussion part	31
6.1. Trade-offs Between Security and Decentralization	31
6.2. Future Trends in DeFi Security	32
7. Conclusion.....	34
7.1. Answers to the Research Questions.....	34
7.2. Summary of Key Findings.....	35
References	36

1. Introduction

1.1. Background and Context of DeFi

Decentralized Finance (DeFi) is a new type of financial system that uses blockchain technology to provide services like lending, borrowing, and trading without traditional banks or institutions. Blockchain, the technology behind cryptocurrencies like Bitcoin (Bhutta et al., 2021), allows people to make transactions directly with each other using smart contracts. These are self-executing agreements written in code, which automatically complete tasks when conditions are met (Abuhashim & Tan, 2020). DeFi started growing quickly after Ethereum, a blockchain platform that supports smart contracts, became popular. Today, DeFi platforms manage billions of dollars in assets, showing their importance in the global economy (Wang et al., 2023).

The main idea of DeFi is to create a financial system that is open to everyone, without needing permission from authorities. Unlike traditional finance, which requires identity checks and middlemen, DeFi lets anyone with an internet connection participate (Sriman & Kumar, 2022). This has advantages, such as faster transactions and access for people in countries with weak banking systems. However, because DeFi is built on new technology, it also faces unique challenges. For example, smart contracts can have errors in their code, and hackers often target these weaknesses to steal money (Li et al., 2022). Additionally, DeFi relies on decentralized networks, which means there is no central authority to fix problems or help users if something goes wrong.

The growth of DeFi has changed how people think about money and financial services. Supporters believe it can reduce inequality and give people more control over their finances (Alamsyah & Salsabila, 2024). At the same time, critics warn that the lack of rules and frequent security issues make DeFi risky for users. Recent studies reveal that hackers and scammers stole more than \$3 billion from DeFi systems in just one year (Zhou et al., 2024). These losses show why stronger security measures are urgently needed to keep users safe and support the growth of decentralized finance. By learning about how DeFi works and the risks it faces, developers and users can work together to improve its security. This understanding is important for making DeFi a trustworthy option compared to traditional banks and financial systems in the future. Problem Statement: Security Challenges in DeFi.

1.2. Problem Statement: Security Challenges in DeFi

Decentralized Finance (DeFi) has expanded quickly, providing banking services such as loans and exchanges without using normal financial institutions. But this fast growth has also led to important security risks. A big problem is that DeFi platforms frequently get attacked by criminals since they manage huge sums of money and depend on complicated technology. For instance, smart contracts - the self-executing digital agreements on blockchain - sometimes have mistakes in their code. Hackers can use these mistakes to steal money, like what happened in the 2016 DAO hack when attackers stole \$60 million because of a coding error in a smart contract (Li et al., 2022).

Another challenge is the use of flash loans, which allow users to borrow large amounts of cryptocurrency without collateral. While useful, these loans have been misused to manipulate DeFi platforms. In 2021, attackers used flash loans to exploit the Poly Network, stealing over 600 million (Xia et al., 2023). Additionally, “rugpulls,” where developers abandon projects after collecting user funds, are common. Over 2.8 billion was lost to such scams in 2021 alone (Zhou et al., 2024).

Current solutions, like audits and security tools, are not enough. Audits check smart contracts for errors, but many projects skip them to save time or money (Sujeetha & Deiva Preetha, 2021). Moreover, DeFi’s decentralized nature makes it hard to recover stolen funds or punish attackers. A clear example is the AnubisDAO scam in 2021, where investors lost \$60 million because the project creators suddenly disappeared with the money (AlFaw et al., 2022). Since the developers hid their identities, no one could hold them responsible. Problems like this demonstrate that while DeFi brings new financial possibilities, it still fails to keep users safe. Unless these security issues get fixed, DeFi will not earn full confidence of people or become a reliable replacement for regular banking systems.

1.3. Research Objectives and Questions

This research aims to better understand security risks in decentralized finance (DeFi) and find ways to improve protection. The study will first look at common problems in DeFi systems built on blockchain technology. These include mistakes in smart contracts and attacks on trading pools that have caused large financial losses (Li et al., 2022). Next, it will examine current safety measures like code checks and decision-making systems, showing why they sometimes fail to stop hackers

(Sujeetha & Deiva Preetha, 2021). The seriousness of this issue is clear from the \$3 billion stolen from DeFi platforms in 2023, which proves current protections are not working well enough (AlFaw et al., 2022). The research will also study how special features of DeFi, like automatic systems and shared control, create risks that don't exist in regular banks.

The study aims to answer three key questions:

Q1: How do technical flaws in DeFi systems make them vulnerable to attacks?

Q2: Why do current security practices, such as audits or insurance funds, often fail to protect users?

Q3: What new strategies can be developed to reduce risks related to both technology and human factors, such as poor decision-making in decentralized organizations?

By answering these questions, the research of this Thesis will help create better safety standards for DeFi platforms. This work is important because safer DeFi systems could increase trust in blockchain technology and support its use for financial services worldwide (Sriman & Kumar, 2022).

1.4. Significance of the Study

The significance of this study lies in addressing the urgent security problems faced by decentralized finance (DeFi) systems, which have become a critical part of the global financial system. DeFi platforms manage billions of dollars in user funds, but frequent security breaches threaten their growth and user trust. For example, hackers stole over \$3.1 billion from DeFi platforms in 2022 alone, mainly due to smart contract vulnerabilities and protocol weaknesses (Li et al., 2022). These security problems lead to more than just money losses - they also make people doubt blockchain technology.

Studying these risks matters because DeFi provides important services like loans and trading without needing banks, helping those who can't use normal banking (Sriman & Kumar, 2022). But if security stays weak, many users won't trust DeFi platforms. This research works to find major dangers like flash loan attacks and exit scams, while testing ways to improve safety (Xia et al., 2023; Zhou et al., 2024). While earlier studies mostly looked at technical problems, this paper also investigates money-related and management risks that others have overlooked (Babel et al., 2023).

2. Literature Review

2.1. Overview of Blockchain and DeFi Ecosystems

Blockchain technology forms the basis of decentralized finance (DeFi). It is a shared digital record that stores transaction data across many computers, making it secure, transparent, and difficult to alter (Bhutta et al., 2021). Unlike traditional banking systems, blockchain operates without a central authority. Instead, it uses methods like Proof of Work (PoW) or Proof of Stake (PoS) to verify transactions and keep the network running (Abuhashim & Tan, 2020). This decentralized structure is what makes blockchain essential for DeFi.

DeFi is a financial system built on blockchain that provides services such as loans, borrowing, and trading without banks or middlemen (Sriman & Kumar, 2022). It relies on smart contracts—self-executing programs on the blockchain—that automatically carry out transactions when certain conditions are met (Çulha & Yazici, 2024). For instance, if a user wants to borrow money, the smart contract releases the funds immediately after receiving the required collateral, removing the need for a trusted third party.

The DeFi ecosystem consists of several key parts. Decentralized exchanges (DEXs) let users trade cryptocurrencies directly, without a central company controlling the trades (Košťál et al., 2023). Lending platforms enable users to lend or borrow assets using smart contracts. Stablecoins, which are cryptocurrencies pegged to stable assets like the US dollar, help reduce price swings in DeFi (Wang et al., 2023). Additionally, liquidity pools supply funds for trading on DEXs, and users who deposit their money into these pools earn rewards.

DeFi has grown very quickly. In 2020, the total value locked (TVL) in DeFi projects was about 1 billion, but by 2023, it had increased to over 100 billion. This fast growth shows how widely DeFi is being used. However, it has also created security risks. Since DeFi depends on smart contracts, coding errors can be exploited by hackers, leading to major losses (Li et al., 2022). Understanding how blockchain and DeFi work—and the risks they face—is crucial for making them safer in the future.

2.2. Existing Research on DeFi Vulnerabilities

The rapid growth of Decentralized Finance (DeFi) has been accompanied by significant security concerns that researchers continue to investigate. A primary focus has been on smart contract vulnerabilities, which serve as the foundation of DeFi platforms. Studies reveal that coding errors in these contracts frequently enable exploitation, with reentrancy attacks being particularly damaging. In such attacks, hackers repeatedly withdraw funds before balances update, leading to substantial losses (Li et al., 2022).

Oracle manipulation represents another critical vulnerability in DeFi systems. These external data providers can be compromised to deliver false information to smart contracts, resulting in incorrect executions. Research by Babel et al. (2023) demonstrated this risk through analysis of the bZx attack, where manipulated price data enabled multi-million dollar thefts. Similarly concerning are flash loan attacks, where perpetrators exploit DeFi's permissionless lending features. As Xia et al. (2023) documented, attackers temporarily borrow large sums without collateral, manipulate markets, and repay loans within single transactions - all while profiting from the artificial price movements they create.

Exit scams, commonly called "rug pulls," remain prevalent threats. Zhou et al. (2024) examined numerous cases where developers abandoned projects after collecting investor funds, often facilitated by inadequate audits and poor transparency. While security audits represent the current standard for vulnerability detection, their limitations have become apparent. Sujeetha and Deiva Preetha (2021) noted that even audited contracts contain undetected flaws, emphasizing the need for improved security measures beyond conventional approaches.

These findings collectively demonstrate that while research has successfully identified major DeFi vulnerabilities, substantial work remains to develop effective safeguards against these evolving threats. The unique architecture of decentralized systems continues to present novel security challenges that demand innovative solutions.

2.3. DeFi Attacks (Flash Loans, Smart Contracts, Rug Pulls)

DeFi systems face significant security threats, particularly from flash loan attacks, smart contract exploits, and fraudulent rug pulls. These vulnerabilities have resulted in substantial financial

damages and eroded user confidence in decentralized platforms. A thorough examination of these attack vectors is crucial for developing more robust protective measures.

Flash loans represent both an innovative feature and a potential vulnerability in DeFi ecosystems. These uncollateralized loans enable users to borrow substantial cryptocurrency amounts within a single transaction block, provided the funds are repaid immediately. While designed for legitimate purposes like arbitrage opportunities, this mechanism has been weaponized by malicious actors. Attackers exploit flash loans to artificially manipulate asset prices on decentralized exchanges through coordinated trading activities. By flooding markets with large, temporary positions, they can distort price oracle data and execute profitable trades based on these artificial valuations. The 2020 bZx attack serves as a prominent case study, where attackers employed this method to extract millions of dollars (Xia et al., 2023). These attacks show how powerful tools in DeFi can be misused if not properly secured.

Smart contract vulnerabilities are another major issue in DeFi. Smart contracts are programs that run on blockchains and automate financial transactions. However, if there are bugs or errors in the code, attackers can exploit them. For example, reentrancy attacks happen when a malicious contract repeatedly calls a vulnerable function before the first call is finished. This was the cause of the famous DAO hack in 2016 (Li et al., 2022). Another common vulnerability is integer overflow, where numbers exceed their maximum limit, leading to unexpected behavior. Many DeFi projects fail to properly test their smart contracts, leaving them open to exploitation (Sujeetha & Deiva Preetha, 2021). These vulnerabilities show the importance of thorough code audits and testing.

Rug pulls are another type of attack that targets users' trust. In a rug pull, developers of a DeFi project suddenly withdraw all the funds from the project, leaving investors with worthless tokens. These security issues frequently occur in projects with insufficient liquidity or inadequate governance structures. A notable case occurred in 2021 when AnubisDAO abruptly vanished with more than \$60 million of investor capital (Zhou et al., 2024). Such exit scams prove particularly prevalent in emerging or minimally regulated initiatives, where project creators can maintain anonymity with relative ease. Enhanced regulatory oversight and improved transparency measures could significantly mitigate these fraudulent activities.

Flash loan exploits, smart contract weaknesses, and exit scams represent critical vulnerabilities within DeFi ecosystems. These attacks capitalize on technical deficiencies, governance shortcomings, and the inherent trust placed in decentralized systems. Although protective measures such as comprehensive code audits and strengthened regulatory frameworks have been suggested, substantial additional research remains necessary to effectively counter these threats. A deeper examination of attack methodologies and their underlying mechanisms represents an essential step toward developing more resilient DeFi infrastructures. Current understanding of these vulnerabilities, while growing, still requires expansion to address the evolving sophistication of malicious actors targeting decentralized financial platforms. Future security solutions must account for both technical and human factors to establish truly robust protections against these multifaceted threats.

2.4. Current Mitigation Strategies and Their Limitations

Several security strategies have emerged to address DeFi vulnerabilities, each with distinct advantages and limitations. Smart contract audits represent the most widely adopted approach, where specialized firms conduct thorough code examinations to identify potential weaknesses before deployment (Sujeetha & Deiva Preetha, 2021). While these audits significantly improve security, they remain imperfect - sophisticated vulnerabilities may evade detection, and the substantial costs involved create barriers for smaller projects. The historical compromise of audited contracts demonstrates that audits alone cannot guarantee complete protection.

Formal verification offers a more rigorous alternative, employing mathematical proofs to verify code correctness (Babel et al., 2023). This method can uncover subtle errors that conventional audits might overlook, providing stronger assurances of contract reliability. However, the technique demands specialized expertise, significant time investments, and proves less effective for contracts involving complex external interactions. These constraints currently limit its practical application across the diverse DeFi ecosystem.

Decentralized governance models attempt to enhance security through community oversight, distributing decision-making authority among token holders (Košťál et al., 2023). This approach aims to prevent centralized control abuses but faces implementation challenges including low voter participation, disproportionate influence by major stakeholders, and emerging threats like governance attacks that manipulate voting mechanisms.

Insurance protocols have gained traction as a risk mitigation tool, allowing users to hedge against potential losses from security breaches (Yu et al., 2021). These solutions provide valuable financial safeguards but cannot prevent attacks from occurring. Insurance mechanisms also face challenges in accurately pricing risk and maintaining sufficient liquidity to cover large-scale incidents. The effectiveness of coverage depends heavily on precise policy terms and claims assessment processes, which remain works in progress. The cost of insurance can be high, and coverage is often limited. Furthermore, insurance protocols themselves can be vulnerable to attacks, creating a new layer of risk.

Finally, some projects are using bug bounty programs to improve security. In these programs, developers offer rewards to anyone who can find and report vulnerabilities in their code. This can help identify issues before they are exploited by attackers (Leong et al., 2024). However, bug bounty programs rely on the skills and honesty of participants. Not all vulnerabilities may be found, and some participants may choose to exploit the vulnerabilities instead of reporting them.

While there are several strategies to mitigate security risks in DeFi, each has its limitations. Audits and formal verification are effective but costly and time-consuming. Decentralized governance can reduce centralization risks but faces challenges like low participation and governance attacks. Insurance provides financial protection but can be expensive and limited in scope. Bug bounty programs encourage community involvement but are not attack-proof. These limitations highlight the need for more research and innovation to develop better solutions for securing the DeFi ecosystem.

3. Fundamentals of DeFi Systems

3.1. Key Components of DeFi (Lending Protocols, DEXs, Stablecoins)

Decentralized finance (DeFi) systems depend on three main parts to work: lending protocols, decentralized exchanges (DEXs), and stablecoins. Each part plays a special role in allowing users to trade, borrow, or save money without needing traditional banks.

Lending protocols let users borrow digital assets or earn interest by lending their own assets. These platforms, like Aave or Compound, use smart contracts to automatically manage loans and set interest rates based on supply and demand (Sriman & Kumar, 2022). However, if the smart

contracts have errors, users can lose their funds. For example, a coding mistake in a lending protocol could allow hackers to take money without paying it back (Li et al., 2022).

Another important part of DeFi is decentralized exchanges (DEXs), which allow users to trade cryptocurrencies directly with each other. Unlike centralized exchanges (like Binance), DEXs such as Uniswap or Sushiswap use liquidity pools. In these pools, users provide funds to enable trades, and they earn fees in return (Košťál et al., 2023). However, DEXs face risks like "front-running," where attackers manipulate trade orders to profit unfairly (Xia et al., 2023).

Finally, stablecoins are cryptocurrencies designed to keep a stable value, usually tied to a real-world asset like the US dollar. Examples include USDC and DAI. Stablecoins help reduce price swings in DeFi transactions. However, they are not always safe. For instance, if a stablecoin's reserves are not properly checked, it might lose its value suddenly (Wang et al., 2023). Some algorithmic stablecoins, which use code instead of real assets, have also failed in the past, causing large losses (Zhou et al., 2024).

Together, these components form the base of DeFi systems. However, their technical complexity and reliance on code create many security challenges that need to be solved.

3.2. Technical Mechanisms: Smart Contracts, Oracles, Liquidity Pools

Smart contracts are computer programs that automatically execute actions when specific conditions are met. They are the backbone of DeFi systems because they replace traditional financial middlemen with code (Bhutta et al., 2021). For example, lending platforms like Aave use smart contracts to manage loans without banks. However, errors in smart contract code can lead to serious security problems. A study found that 45% of DeFi hacks occur due to mistakes in smart contract programming (Li et al., 2022). This shows why audits and testing are critical before deploying contracts.

Oracles are services that connect blockchains to real-world data, such as cryptocurrency prices. DeFi platforms like Chainlink use oracles to ensure accurate information for trading or lending decisions. However, if an oracle is hacked or provides wrong data, the entire system can fail. For instance, a wrong price feed from an oracle caused a \$90 million loss for a DeFi platform in 2022 (Babel et al., 2023). This highlights the risk of relying on centralized oracles.

Liquidity pools are pools of tokens locked in smart contracts to enable trading on decentralized exchanges (DEXs) like Uniswap. Users who add tokens to these pools earn fees from trades. While liquidity pools make trading easier, they face risks like "impermanent loss," where the value of tokens in the pool drops compared to holding them separately (Košťál et al., 2023). Hackers also target liquidity pools because they hold large amounts of assets. For example, attackers exploited a vulnerability in a liquidity pool's smart contract to steal \$600 million in 2022 (Xia et al., 2023).

3.3. Economic and Governance Models in DeFi

Decentralized Finance (DeFi) relies on economic and governance structures designed to create transparent, trustless financial services without centralized control. These frameworks shape user interactions, decision-making processes, and value distribution within DeFi platforms. While they enable innovative financial solutions, they also present distinct security and fairness challenges that must be addressed to ensure system stability and user protection.

The economic foundation of DeFi depends on incentive mechanisms that encourage user participation. Liquidity providers (LPs), for instance, receive fees and governance tokens in exchange for depositing assets into trading pools that power decentralized exchanges (DEXs). These rewards aim to maintain sufficient liquidity for smooth platform operations. However, such incentive models can create unintended consequences. Excessively high yields may attract short-term speculators rather than long-term participants, potentially destabilizing protocols (Bhutta et al., 2021). Moreover, an overemphasis on token rewards often shifts user focus from platform utility to speculative trading, fostering volatile market conditions that undermine ecosystem health (Sriman & Kumar, 2022).

Governance in DeFi is another critical aspect, as it determines how decisions are made and who has control over the system. Most DeFi platforms use decentralized governance models, where token holders vote on proposals to change the protocol. This is often done through a system called Decentralized Autonomous Organizations (DAOs). DAOs aim to give power to the community, but they are not without issues. The governance models in DeFi systems present several critical challenges that can compromise their decentralized nature. A fundamental issue stems from the token-based voting system, where decision-making power directly correlates with token ownership. This structure inherently favors wealthier participants, creating a paradox where decentralized platforms become controlled by a small group of large token holders (Košťál et al.,

2023). Such concentration of power contradicts the core principle of decentralization and may lead to decisions that primarily benefit this select group rather than the broader community.

Compounding this issue is the widespread problem of voter participation. Many token holders choose not to engage in governance processes, resulting in low turnout that amplifies the influence of active participants. This dynamic creates governance systems that may not represent the diverse interests of all stakeholders, potentially leading to biased or shortsighted decisions. The absence of broad participation undermines the democratic ideals that DeFi governance models aim to achieve.

Accountability represents another significant governance challenge in DeFi ecosystems. Unlike traditional financial systems that operate within established regulatory frameworks, DeFi platforms lack formal oversight mechanisms. Decisions are made by pseudonymous or anonymous participants, with no legal safeguards to protect users' interests (Li et al., 2022). This regulatory vacuum enables governance attacks, where malicious actors exploit the voting system to approve harmful proposals. Notable incidents have demonstrated how attackers can accumulate governance tokens to legitimize proposals that drain platform funds, highlighting the vulnerability of current governance structures.

These governance challenges reveal a tension between decentralization ideals and practical implementation. While DeFi aims to eliminate centralized control, the current governance models struggle to achieve true decentralization while maintaining security and fair representation. Addressing these issues requires innovative solutions that balance participation incentives, power distribution, and accountability without compromising the permissionless nature of decentralized systems.

3.4. Security as a Core Challenge

DeFi systems face serious security risks because they use blockchain and smart contracts instead of banks. While this makes financial services more open, it also creates new dangers. These problems come from technical issues, mistakes in smart contracts, and how people use the systems. Without good security, DeFi platforms can be hacked, causing people to lose money and trust.

One big problem is mistakes in smart contracts. These are computer programs that automatically move money when certain conditions are met. If the code has errors, hackers can steal funds or break the system. A famous example is the DAO hack in 2016, where hackers stole \$50 million because of one coding mistake (Li et al., 2022). This shows how small errors can cause big losses.

Another issue is the use of oracles - services that provide outside information to smart contracts. If hackers change this information, they can trick the system. For example, if a price feed is wrong, attackers can steal money from DeFi platforms (Babel et al., 2023). These "oracle attacks" happen often in DeFi.

Money and control systems in DeFi also cause security problems. Many platforms let users vote with tokens, but this means rich users have more power. Sometimes developers or big token holders cheat the system, taking all the money and disappearing (Zhou et al., 2024). Also, flash loans let people borrow lots of money without collateral, which hackers use to trick the system (Xia et al., 2023).

Current security measures, such as code audits and bug bounty programs, are helpful but not enough to fully protect DeFi systems. Code audits involve experts reviewing smart contract code to find vulnerabilities, but they cannot catch every issue (Sujeetha & Deiva Preetha, 2021). Bug bounty programs reward users for finding and reporting bugs, but they rely on external participants and may not prevent all attacks (Leong et al., 2024). As DeFi continues to grow, new and more advanced security solutions will be needed to address these challenges.

4. Analysis of DeFi Attack Types

4.1. Flash Loan Attacks

4.1.1. Mechanics of Flash Loans

Flash loan attacks are one of the most common and damaging types of attacks in decentralized finance (DeFi). These attacks take advantage of the unique features of flash loans, which allow users to borrow large amounts of cryptocurrency without providing collateral, as long as the loan is repaid within the same transaction. Flash loans were created to help traders take advantage of price differences and use money more efficiently (Xia et al., 2023). However, hackers have found

ways to use them for attacks. These loans work because blockchain transactions happen completely or not at all - users borrow money, use it, and pay it back all in one transaction. If they can't pay it back, the transaction cancels so lenders don't lose money. But attackers use this system to trick DeFi platforms. For example, they might borrow lots of cryptocurrency, change an asset's price on an exchange, then make money from this artificial price change before paying back the loan (Li et al., 2022).

A popular attack method involves tricking price information systems. These systems tell smart contracts what prices are in the outside world. Attackers use flash loans to trade huge amounts quickly, making prices go up or down unnaturally. Then they use these fake prices to steal from lending platforms or other DeFi services that trust this data (Babel et al., 2023). Another method is finding mistakes in smart contract code that let attackers take money out. These attacks need technical skill but can steal large amounts.

These problems show how hard it is to keep DeFi safe. Flash loans themselves aren't bad, but how people misuse them proves we need better protection. Solutions could include safer price information systems, stricter code checks, and watching transactions more closely (Leong et al., 2024). Learning how these attacks work helps create better defenses and keep DeFi systems stable in the future.

4.1.2. Case Examples

Flash loan attacks have become one of the most serious threats in decentralized finance (DeFi). These attacks use a special feature that lets people borrow large amounts of cryptocurrency without collateral, as long as they pay it back immediately. Hackers use this feature to trick the system, change market prices, and steal money from DeFi platforms. Two major attacks - PancakeBunny and Harvest Finance - show how dangerous these exploits can be.

In May 2021, the PancakeBunny platform was attacked when a hacker borrowed lots of Binance Coin (BNB) using a flash loan. The hacker used this money to artificially increase the price of BUNNY tokens. When the price went up, they created new BUNNY tokens and sold them at the high price. This caused the token value to drop suddenly, resulting in over \$200 million in losses for users (Xia et al., 2023). This attack showed how flash loans could be used to manipulate token prices.

Another serious attack happened to Harvest Finance in October 2020. The hacker used a flash loan to change the prices of stablecoins on Curve Finance, which was connected to Harvest Finance. By quickly trading between different stablecoins, the hacker created an imbalance in the money pools. This allowed them to take out more money than they put in, stealing about \$24 million (Li et al., 2022). This case showed how problems in one DeFi platform can affect others that are connected to it.

These examples prove that flash loan attacks are a major danger to DeFi. They take advantage of weaknesses in how smart contracts, price information systems, and money pools are designed. While flash loans can be useful for legitimate trading, they can also be used for attacks. Developers are working on solutions like better price systems, improved money pool controls, and stricter code checks (Babel et al., 2023). As DeFi keeps growing, new security challenges will appear, making constant research and improvement necessary to protect users' money.

4.1.3. Exploitation Pathways and Impact

Flash loan attacks have emerged as one of the most dangerous security problems in decentralized finance. These attacks take advantage of a special DeFi feature that lets users borrow large sums of cryptocurrency without putting up any collateral, as long as they pay back the loan immediately. While this feature was created to help traders find good deals and move money efficiently, hackers have learned how to use it to cheat the system. These attacks often involve complicated interactions between different smart contracts, making them hard to spot and stop (Xia et al., 2023).

One way hackers use flash loans is by changing token prices unfairly. They borrow huge amounts of a cryptocurrency and use it to artificially push the price up or down on a decentralized exchange. Then they use these fake prices to steal money from lending platforms or other DeFi services that rely on accurate price information (Babel et al., 2023). This works because many DeFi platforms use price information systems that can be tricked by large, sudden trades.

Another method involves finding mistakes in how smart contracts are programmed. Flash loans give attackers the temporary funds they need to trigger special conditions in contracts that would normally be impossible to reach. For example, a hacker might use a flash loan to briefly meet the requirements for borrowing from a lending platform, take out extra money, and then pay back the

original loan before the transaction finishes (Li et al., 2022). This shows why smart contracts need to be designed very carefully and why they shouldn't depend too much on outside information.

These attacks can cause enormous damage. They often steal millions of dollars in cryptocurrency, like the 2020 attacks on bZx that cost over \$1 million (AlFaw et al., 2022). But the harm goes beyond just money - these attacks make people less likely to trust DeFi platforms, and they also bring more attention from regulators who want to control the risks of decentralized finance (Sriman & Kumar, 2022).

Flash loan attacks remain a major security challenge for DeFi. They use the special features of flash loans - no collateral needed and instant repayment - to cheat the system in clever ways. To fight these attacks, developers need to build smarter contracts, create stronger price information systems, and help everyone understand how these attacks work. Only by addressing these issues can DeFi become more secure and trustworthy for all users.

4.2. Smart Contract Vulnerabilities

4.2.1. Common Flaws (Reentrancy, Integer Overflows, Access Control)

Reentrancy attacks represent one of the most dangerous security flaws in smart contracts. This vulnerability occurs when an external contract repeatedly calls back into a vulnerable contract before the original function completes its execution. Attackers exploit this weakness to drain funds from smart contracts in a looping pattern. This type of attack is still relevant today, as many DeFi protocols rely on complex interactions between contracts.

The most famous case of this attack happened in 2016 with "The DAO" project. Hackers discovered a reentrancy flaw in the smart contract's withdrawal function. They created a malicious contract that kept calling back to withdraw funds before the original transaction could update the account balance. This allowed them to steal millions of dollars worth of cryptocurrency (Li et al., 2022). The attack was so severe that it forced Ethereum developers to implement a network-wide change to recover the stolen funds.

Integer overflows and underflows are another common issue in smart contracts. These occur when a number exceeds the maximum or minimum value that can be stored in a variable. For example, if

a contract uses a 256-bit integer and the value goes beyond its limit, it can cause unexpected behavior. This can be exploited by attackers to manipulate balances or bypass checks. Research shows that many early Ethereum contracts were vulnerable to this type of flaw (Abuhashim & Tan, 2020). Although newer programming languages like Solidity have added safeguards, developers must still be careful when handling arithmetic operations.

Access control issues represent a serious security risk in smart contract development. These problems occur when contracts fail to properly limit who can use important functions or view sensitive information. Without proper restrictions, attackers can exploit these weaknesses to perform unauthorized actions, often resulting in stolen funds or damaged systems.

A common example involves fund transfer functions that don't verify user permissions. If a contract allows anyone to call its "send money" function without proper checks, hackers can easily steal all the stored assets. Research on DeFi platforms shows many projects don't use strong enough access controls, making them easy targets for attacks (AlFaw et al., 2022). This demonstrates why careful planning and thorough testing are essential when creating smart contracts.

4.2.2. Case Studies

Smart contract security flaws have caused some of the most expensive attacks in decentralized finance, showing how small coding mistakes can lead to huge financial losses. Two particularly important cases - the 2016 DAO Hack and the 2021 Poly Network Exploit - demonstrate how hackers take advantage of these weaknesses and why better security measures are needed.

The DAO Hack was one of DeFi's first major security disasters and still affects how people view blockchain security today. The DAO (Decentralized Autonomous Organization) functioned as an Ethereum-based investment platform where members could vote on funding proposals. However, a critical error in its smart contract code allowed a hacker to continuously withdraw money before the system recorded the transactions. This reentrancy attack resulted in the theft of more than \$60 million in cryptocurrency (Li et al., 2022). The damage was so severe that Ethereum developers had to create a new version of the blockchain to recover the stolen funds. This incident proved that even popular, well-funded projects could be destroyed by basic programming errors.

The Poly Network Exploit in 2021 showed how vulnerabilities in cross-chain systems can be exploited. Poly Network allowed users to transfer assets between different blockchains. Attackers found a weakness in the smart contract code that verified transactions, enabling them to redirect over \$600 million to their own wallets (Xia et al., 2023). Unlike many attacks, the hackers later returned most of the funds, possibly due to public pressure and difficulty laundering such a large amount. This incident revealed how complex systems connecting multiple blockchains create new risks, as errors in one part of the system can affect others.

Both cases share important lessons. First, even projects designed by experienced teams can have critical flaws if code is not thoroughly tested. The DAO's reentrancy issue and Poly Network's verification errors were preventable with better auditing practices (Sujeetha & Deiva Preetha, 2021). Second, the scale of losses in these attacks shows that DeFi protocols must prepare for worst-case scenarios. Finally, these incidents highlight the importance of community response. In the DAO Hack, the Ethereum community changed the blockchain's rules to recover funds, while in the Poly Network case, public tracking forced the attacker to return stolen assets.

These examples emphasize that smart contract security requires constant attention. As DeFi systems grow more complex, developers must prioritize secure coding practices, regular audits, and emergency response plans (Leong et al., 2024). Learning from past failures remains crucial to building safer decentralized systems.

4.3. Rug Pulls and Exit Scams

4.3.1. Mechanisms of Rug Pulls (Liquidity Removal, Token Minting)

Rug pulls and exit scams are among the most common and damaging attacks in decentralized finance (DeFi). These attacks occur when developers or project creators intentionally deceive users, often by creating a false sense of trust, only to withdraw funds or manipulate the system for their benefit. Rug pulls typically involve the sudden removal of liquidity or the exploitation of token mechanics, leaving investors with worthless assets. Exit scams, on the other hand, involve the complete abandonment of a project after funds have been raised, with no intention of delivering on promises. Both types of attacks exploit the trust and transparency that DeFi systems aim to provide, highlighting significant vulnerabilities in the ecosystem.

One of the primary mechanisms of rug pulls is liquidity removal. In DeFi, liquidity pools are essential for enabling trading on decentralized exchanges (DEXs). Users provide funds to these pools in exchange for rewards, such as trading fees or yield farming incentives. However, malicious actors can create a token, pair it with a legitimate cryptocurrency like Ethereum, and attract liquidity providers by offering high returns. Once a significant amount of funds is deposited into the pool, the attackers withdraw all the liquidity, leaving the token worthless. This sudden removal of liquidity makes it impossible for users to trade or withdraw their funds, resulting in substantial financial losses (Zhou et al., 2024).

Another common mechanism used in rug pulls is token minting. In this scenario, attackers create a token with a hidden function that allows them to mint unlimited tokens at any time. Initially, the token may appear legitimate, and its value may rise as more users invest. However, once the attackers decide to execute the rug pull, they mint a large number of tokens and sell them on the market. This massive sell-off causes the token's price to crash, leaving investors with assets that have little to no value. Token minting attacks are particularly dangerous because they can be executed without warning, and the malicious code is often hidden within the smart contract, making it difficult for users to detect (Alamsyah & Salsabila, 2024).

Rug pulls and exit scams are not only financially devastating but also erode trust in the DeFi ecosystem. Many users are drawn to DeFi because of its promise of decentralization and transparency. However, these attacks demonstrate that malicious actors can exploit the system's openness for personal gain. While some projects undergo audits to identify vulnerabilities, many rug pulls occur in unaudited or poorly audited projects. This highlights the need for better security practices, such as stricter auditing standards and increased user education, to mitigate the risks associated with these attacks (Leong et al., 2024).

4.3.2. Analysis of DeFi Attack Types: Rug Pulls and Exit Scams – Case Studies

Several real-world examples highlight the dangers of rug pulls and exit scams in decentralized finance (DeFi). These cases show how attackers exploit trust and technical weaknesses to steal funds. Two well-known examples are the Squid Game Token and AnubisDAO incidents. Studying these cases helps to understand how such attacks happen and their effects on the DeFi ecosystem.

The Squid Game Token is a famous example of a rug pull. This token was created in 2021 and named after the popular Netflix series. It attracted many investors because of its connection to the show and promises of high returns. However, the developers included hidden controls in the smart contract. These controls allowed them to block users from selling the token. After the token's price increased rapidly, the developers removed all liquidity from the trading pool. This caused the token's value to drop to nearly zero, resulting in losses of millions of dollars for investors. The Squid Game Token case shows how attackers use hype and hidden code to trick users (Zhou et al., 2024).

Another example is AnubisDAO, a project that raised over \$60 million in 2021. The project claimed to be a decentralized investment platform. However, shortly after collecting funds, the developers transferred all the money to private wallets and disappeared. Investors could not recover their funds because the project's governance structure gave the developers full control. The AnubisDAO exit scam demonstrates how fake projects can use decentralized branding to hide centralized control. This makes it easier for attackers to steal funds without being caught (Alamsyah & Salsabila, 2024).

Both cases share common factors that allowed the attacks to succeed. First, the projects lacked proper audits or transparency. For example, the Squid Game Token's smart contract was not checked by independent experts, so the malicious code remained hidden (Sujeetha & Deiva Preetha, 2021). Second, investors were influenced by social media trends and fear of missing out (FOMO), leading them to ignore risks. Researchers note that many DeFi scams succeed because users prioritize high rewards over security (Sriman & Kumar, 2022).

These case studies highlight the importance of caution in DeFi. While the technology offers new opportunities, it also creates risks when projects are not properly regulated or audited. Learning from past attacks can help users identify warning signs, such as anonymous teams or unaudited contracts. It also emphasizes the need for better education and tools to protect investors in decentralized systems.

4.4. Root Cause Analysis and Lessons Learned

Studying real-world DeFi attacks reveals common patterns behind their success and provides important lessons for improving security. Many exploits happen due to weaknesses in smart contracts, poor governance structures, or human errors. For example, in cases like the Squid Game Token and AnubisDAO scams, attackers used hidden code or false promises to trick users (Zhou et al., 2024). These incidents show how technical flaws and lack of transparency create opportunities for fraud.

A major root cause of DeFi attacks is the complexity of smart contracts. Even small coding mistakes can lead to big vulnerabilities. For instance, some smart contracts allow developers to mint unlimited tokens or control liquidity pools without user approval (Li et al., 2022). Attackers exploit these features to drain funds suddenly. Additionally, projects that skip audits or use unaudited code are more likely to suffer attacks (Sujeetha & Deiva Preetha, 2021). Audits help find hidden risks, but many projects ignore this step to save time or money, leaving users unprotected.

Another issue is the misuse of decentralized branding. Some projects claim to be decentralized but keep central control over funds or decisions. In exit scams like AnubisDAO, developers pretended to follow community governance but secretly held full power (Alamsyah & Salsabila, 2024). This false decentralization makes it easy for attackers to steal funds without checks. Users often trust projects that appear decentralized, not realizing the team can override rules or disappear with their money.

Human behavior also plays a role in these attacks. Many users invest in DeFi projects without researching the team or technology. Social media hype and fear of missing out push people to make quick decisions. For example, the Squid Game Token's popularity grew rapidly due to its connection to a TV show, even though the project had no real use (Sriman & Kumar, 2022). Attackers take advantage of this behavior by creating fake excitement to attract investors before disappearing.

The lessons from these attacks are clear. First, technical solutions like thorough audits and secure coding practices are essential to reduce risks (Babel et al., 2023). Projects should use third-party audits and open-source their code for community review. Second, true decentralization requires checks and balances to prevent central control (Košťál et al., 2023). Governance models should

ensure decisions are made by the community, not just developers. Finally, user education is critical (Leong et al., 2024). Investors must learn to identify red flags, such as anonymous teams or promises of guaranteed profits.

By addressing these root causes, the DeFi ecosystem can become safer and more sustainable. While innovation in blockchain technology offers many opportunities, balancing progress with security will remain a key challenge for the future.

5. Proposed Mitigation Strategies

5.1. Technical Solutions

5.1.1. Smart Contract Auditing Tools and Best Practices

One of the most effective ways to prevent DeFi attacks is through proper smart contract auditing. Since many exploits happen due to coding errors or hidden functions, thorough checks before deployment can catch vulnerabilities early. Automated auditing tools scan smart contracts for common security issues like reentrancy attacks, overflow errors, or unauthorized access controls (Babel et al., 2023). These tools work by analyzing the code against known attack patterns and flagging potential risks. While not perfect, they provide a first layer of defense that can identify obvious problems before real money is at risk.

Manual audits by security experts are equally important. Unlike automated tools, human auditors can understand the contract's logic and business purpose, which helps find more complex vulnerabilities (Sujeetha & Deiva Preetha, 2021). Professional auditing firms examine not just the code itself but also how different parts of the system interact. They test for scenarios that automated tools might miss, such as governance attacks or economic loopholes. Many successful projects now make audit reports public to build trust, showing users that independent experts have reviewed their systems.

Best practices in smart contract development also play a key role in preventing attacks. Developers should follow established security standards and use well-tested code patterns (Abuhashim & Tan, 2020). For example, reusing secure, audited code from trusted libraries reduces the chance of introducing new bugs. Implementing features like time locks or multi-signature wallets can prevent

sudden fund withdrawals by malicious actors (Leong et al., 2024). Another good practice is to keep contracts simple, as complex code increases the risk of hidden vulnerabilities. Regular updates and monitoring after deployment help catch new threats that might emerge over time.

Education and community involvement further strengthen these technical solutions. Many platforms now encourage bug bounty programs, where white-hat hackers get rewarded for finding and reporting vulnerabilities (Li et al., 2022). Open-source projects benefit from public code reviews where anyone can examine and improve the security. Developers should stay updated on new attack methods and share knowledge through security workshops or industry standards.

While no solution can guarantee complete safety, combining automated tools, professional audits, and secure development practices significantly reduces risks (AlFaw et al., 2022). As DeFi continues to grow, these technical measures will remain essential for protecting users and maintaining trust in decentralized systems. The key is making security a priority from the earliest stages of development rather than treating it as an afterthought.

5.1.2. Flash Loan Attack Mitigations (Time Locks, Transaction Limits)

Flash loan attacks have become one of the most dangerous threats in DeFi, allowing attackers to manipulate markets and steal funds without needing any initial capital. These attacks work by borrowing large amounts of cryptocurrency instantly, using it to exploit price differences or protocol weaknesses, and then repaying the loan in the same transaction (Xia et al., 2023). While flash loans themselves are a useful financial tool, they can be weaponized when combined with vulnerable DeFi protocols. Several technical solutions can help reduce these risks, including time locks and transaction limits.

One effective method to prevent flash loan attacks is implementing time locks for critical operations. Time locks require certain actions, like changing protocol parameters or withdrawing large amounts of funds, to wait for a set period before executing (Babel et al., 2023). This delay gives users and developers time to notice suspicious changes and react before damage occurs. For example, if an attacker tries to manipulate governance voting using flash loans, a time lock would prevent the changes from taking effect immediately. During this waiting period, the community could identify the attack and stop it. Time locks are particularly useful for protecting decentralized governance systems where sudden changes could lead to fund losses.

Another approach is setting transaction limits on how much value can be moved or borrowed in a single operation. Since flash loan attacks rely on extremely large, instant transactions, limiting the size of these operations can reduce their impact (Košťál et al., 2023). Protocols can establish maximum amounts for single transactions based on normal usage patterns, making it harder for attackers to manipulate prices or drain liquidity pools. Some platforms implement dynamic limits that adjust based on market conditions, becoming stricter during periods of high volatility when attacks are more likely. While transaction limits might affect some legitimate large-scale operations, the trade-off improves overall security.

Combining these solutions with proper price oracle design provides even stronger protection. Many flash loan attacks succeed because protocols rely on single price sources that can be manipulated (Li et al., 2022). Using multiple oracles with delay mechanisms makes price manipulation much harder. Additionally, protocols can implement circuit breakers that automatically pause trading when unusual activity is detected, similar to traditional stock markets. These pauses give time to investigate potential attacks before they cause significant harm.

While no single solution can completely eliminate flash loan attacks, combining time locks, transaction limits, and secure oracle design creates multiple layers of defense (Leong et al., 2024). As DeFi protocols continue to evolve, developing more sophisticated protections against these attacks will be crucial for maintaining a secure ecosystem. The key challenge is balancing security measures with maintaining the open and permissionless nature that makes DeFi valuable, requiring careful design and constant improvement of these technical solutions.

5.1.3. Rug Pull Prevention

Rug pulls remain one of the most common threats in DeFi, where developers suddenly abandon projects after taking investors' money. These scams undermine trust in decentralized finance and cause significant financial losses (Zhou et al., 2024). However, technical solutions like token locking and Know Your Customer (KYC) verification for developers can help prevent such fraudulent activities. These measures create accountability and reduce opportunities for malicious actors to disappear with investors' funds.

Token locking mechanisms are one of the most effective ways to prevent rug pulls (Košťál et al., 2023). This approach requires developers to lock a portion of the project's tokens or liquidity pool

funds for a set period. Smart contracts automatically enforce these locks, preventing developers from withdrawing or selling their tokens before the predetermined time ends. Some projects use vesting schedules that gradually release tokens to developers over months or years, aligning their interests with long-term project success. Liquidity provider (LP) tokens can also be locked to ensure trading pools remain funded. When investors see that funds are securely locked, they gain confidence that developers cannot easily execute a rug pull. Several blockchain platforms now offer standardized locking solutions that projects can implement easily.

Another important prevention method is requiring KYC verification for development teams (Leong et al., 2024). While this may seem contrary to DeFi's anonymous nature, it adds a layer of accountability. Projects can work with third-party verification services that confirm team members' identities without exposing personal details publicly. This process makes it harder for scammers to create multiple anonymous projects and disappear after each scam. Some decentralized exchanges now give preference to KYC-verified projects, making them more visible to investors. KYC does not guarantee honest behavior, but it increases the risk for potential scammers since their real identities could be revealed if they commit fraud.

Combining these technical solutions with transparent project practices creates stronger protection against rug pulls (Alamsyah & Salsabila, 2024). Projects should provide clear documentation about token distribution, fund allocation, and development roadmaps. Regular audits by reputable firms further verify that the project follows its stated plans (Sujeetha & Deiva Preetha, 2021). Community governance can also play a role, allowing token holders to vote on major decisions like fund withdrawals. While no solution is perfect, these measures together make rug pulls significantly more difficult to execute successfully. As the DeFi space matures, adopting such preventive measures will be crucial for building sustainable projects that protect investors while maintaining the innovative spirit of decentralized finance.

5.2. Economic and Governance Solutions (DAOs, etc.)

5.2.1. Decentralized Insurance Protocols

Decentralized insurance protocols offer a promising way to reduce financial risks in DeFi by allowing users to protect themselves against losses from hacks or system failures (Yu et al., 2021). These protocols work by pooling funds from users who pay premiums, creating a shared insurance

fund that can compensate victims when approved claims are made. Unlike traditional insurance companies, decentralized insurance operates through smart contracts and community governance, removing the need for centralized control. This approach aligns with DeFi's core principles while addressing one of its biggest challenges: the lack of safety nets for users who lose funds to attacks.

One key advantage of decentralized insurance is its transparency (Shelke et al., 2024). All policies, claims, and payouts are recorded on the blockchain, allowing anyone to verify how the system works. When a user buys coverage, the terms are enforced automatically by smart contracts, reducing the risk of unfair denials. Claims are typically reviewed by the community or decentralized organizations, where token holders vote to approve or reject requests based on evidence. This process prevents single entities from controlling decisions, though it requires active participation from the community to function fairly.

However, decentralized insurance faces challenges (Li et al., 2022). Building sufficient funds to cover large-scale attacks is difficult, as the amount of available coverage depends on how many users participate. During periods of frequent attacks, premiums may rise sharply, making insurance too expensive for average users. Additionally, false claims or disputes over whether an event qualifies as a covered risk can create conflicts. Some protocols address this by requiring detailed proof of losses or using automated systems to detect valid claims based on predefined rules.

Governance plays a critical role in improving these systems (Košťál et al., 2023). Token holders can vote on changes to coverage terms, premium rates, or claim approval processes. Over time, decentralized insurance could integrate with other DeFi platforms to offer automatic coverage for common risks, such as smart contract failures or stablecoin depegging. By spreading risk across many participants and encouraging collective responsibility, these protocols help create a safer ecosystem. While not a perfect solution, decentralized insurance represents an important step toward making DeFi more resilient and user-friendly.

5.2.2. Reputation Systems for DeFi Projects

Reputation systems could help solve trust issues in decentralized finance by providing users with clear information about project reliability and team credibility. These systems work by tracking and scoring projects based on their past behavior, security practices, and community feedback. Unlike traditional finance, where institutions build reputations over years, DeFi needs decentralized

methods to assess trustworthiness quickly and transparently. A strong reputation system would allow users to identify safer projects while encouraging developers to follow best practices to maintain high ratings (Alamsyah & Salsabila, 2024; Li et al., 2022).

One approach involves creating on-chain reputation scores that reflect a project's history. For example, projects that complete audits, lock liquidity, or maintain active development could earn higher scores. These scores could be stored on the blockchain and visible to everyone, helping users compare options before investing. Smart contracts might automatically update scores based on verifiable actions, like passing security checks or avoiding controversies. Community members could also contribute by rating projects based on their experiences, similar to review systems in e-commerce platforms. Over time, projects with good reputations would attract more users and investments, creating an incentive for honest behavior (Zhou et al., 2024; Babel et al., 2023).

Reputation systems could also improve governance in decentralized organizations. Projects might give voting power to users based on their reputation scores, ensuring decisions are influenced by experienced community members rather than anonymous accounts. Developers with proven track records could gain more authority in proposing changes, reducing the risk of bad actors taking control. However, designing fair reputation systems is challenging. They must avoid manipulation, such as fake reviews or inflated scores. Solutions might include requiring users to stake tokens when rating projects, making dishonest reviews costly (Sriman & Kumar, 2022; Wang et al., 2023).

Implementing reputation systems faces technical and social challenges. Building accurate scoring models requires analyzing large amounts of on-chain and off-chain data. Privacy concerns must be balanced with transparency, as some users prefer anonymity. Despite these challenges, reputation systems offer a path toward self-regulating DeFi ecosystems. By combining automated tracking with community input, they could reduce scams while preserving decentralization. As DeFi matures, developing reliable reputation mechanisms will be crucial for creating a sustainable environment where trust is earned through actions rather than promises (Košťál et al., 2023; M. N. M. Bhutta et al., 2021).

5.3. Compliance and Transparency

The decentralized nature of DeFi creates challenges for regulation, but some level of oversight is necessary to protect users and maintain market stability. While complete decentralization remains

an important goal, finding the right balance with compliance and transparency can help prevent fraud and build trust in the ecosystem. The key is implementing policies that reduce risks without limiting innovation or going against the core principles of blockchain technology (Sriman and Kumar, 2022).

One important area for improvement is transparency in project operations. Many DeFi platforms operate without clear information about who controls them or how funds are managed. Encouraging projects to disclose basic details about their teams, development processes, and fund allocation would help users make informed decisions. This does not require revealing personal identities completely, but some level of accountability should exist. Public registries of verified projects could help distinguish serious developers from potential scammers. Transparent smart contracts that are open for anyone to review also play a crucial role, as they allow the community to check for suspicious code or hidden functions (Zhou et al., 2024).

Compliance standards could be adapted to fit the DeFi environment without destroying its decentralized nature. Instead of applying traditional financial regulations directly to DeFi, new frameworks should be developed specifically for blockchain-based systems. For example, decentralized identity solutions could allow users to verify their credentials without compromising privacy. Projects might follow voluntary compliance programs that demonstrate their commitment to security and fair practices. Regulatory sandboxes, where new DeFi projects can operate under temporary rules, would allow innovation while monitoring risks. Governments and industry groups should work together to create standards that protect users without forcing centralization (Košťál et al., 2023).

Education is another critical part of improving compliance and transparency. Many users enter DeFi without understanding the risks involved. Clear guidelines about potential scams, smart contract risks, and market volatility should be easily available. Platforms could integrate warning systems that alert users when they interact with unaudited contracts or suspicious projects. Community-driven rating systems might help identify trustworthy platforms based on collective experience rather than centralized authority (Li et al., 2022).

The future of DeFi regulation should focus on creating an environment where good projects can thrive while bad actors face consequences. This requires cooperation between developers, users,

and policymakers to establish practices that maintain security without losing the benefits of decentralization. By promoting transparency and smart compliance solutions, the DeFi space can become more sustainable and accessible to a wider audience while still preserving its innovative potential (M. N. M. Bhutta et al., 2021).

The decentralized nature of DeFi creates challenges for regulation, but some level of oversight is necessary to protect users and maintain market stability. While complete decentralization remains an important goal, finding the right balance with compliance and transparency can help prevent fraud and build trust in the ecosystem. The key is implementing policies that reduce risks without limiting innovation or going against the core principles of blockchain technology (Sriman and Kumar, 2022).

One important area for improvement is transparency in project operations. Many DeFi platforms operate without clear information about who controls them or how funds are managed. Encouraging projects to disclose basic details about their teams, development processes, and fund allocation would help users make informed decisions. This does not require revealing personal identities completely, but some level of accountability should exist. Public registries of verified projects could help distinguish serious developers from potential scammers. Transparent smart contracts that are open for anyone to review also play a crucial role, as they allow the community to check for suspicious code or hidden functions (Zhou et al., 2024).

Compliance standards could be adapted to fit the DeFi environment without destroying its decentralized nature. Instead of applying traditional financial regulations directly to DeFi, new frameworks should be developed specifically for blockchain-based systems. For example, decentralized identity solutions could allow users to verify their credentials without compromising privacy. Projects might follow voluntary compliance programs that demonstrate their commitment to security and fair practices. Regulatory sandboxes, where new DeFi projects can operate under temporary rules, would allow innovation while monitoring risks. Governments and industry groups should work together to create standards that protect users without forcing centralization (Košťál et al., 2023).

Education is another critical part of improving compliance and transparency. Many users enter DeFi without understanding the risks involved. Clear guidelines about potential scams, smart

contract risks, and market volatility should be easily available. Platforms could integrate warning systems that alert users when they interact with unaudited contracts or suspicious projects. Community-driven rating systems might help identify trustworthy platforms based on collective experience rather than centralized authority (Li et al., 2022).

The future of DeFi regulation should focus on creating an environment where good projects can thrive while bad actors face consequences. This requires cooperation between developers, users, and policymakers to establish practices that maintain security without losing the benefits of decentralization. By promoting transparency and smart compliance solutions, the DeFi space can become more sustainable and accessible to a wider audience while still preserving its innovative potential (M. N. M. Bhutta et al., 2021).

6. Discussion part

6.1. Trade-offs Between Security and Decentralization

The relationship between security and decentralization in DeFi has always presented a complex challenge that requires careful balance. While decentralization is the foundation of blockchain technology, achieving strong security often involves some level of centralization or compromise. This tension creates important trade-offs that developers and users must consider when building and interacting with DeFi platforms. Understanding these trade-offs helps explain why certain security vulnerabilities exist and what solutions might be possible without losing the core benefits of decentralization (Sriman and Kumar, 2022).

One major trade-off appears in governance structures. Fully decentralized systems give power to all token holders, but this can lead to slow decision-making when quick action is needed to stop attacks or fix vulnerabilities. More centralized systems with smaller governance groups can respond faster to security threats, but they risk becoming controlled by a few powerful members. Some projects try to find middle ground by having emergency response teams that can act quickly in crises, while still keeping most decisions in community hands. This shows how perfect decentralization may not always be practical for security, but complete centralization goes against what makes DeFi valuable (Košťál et al., 2023).

Security measures like KYC requirements present another important trade-off. While verifying user identities can prevent fraud and comply with regulations, it conflicts with the privacy and permissionless ideals of blockchain. Many DeFi users value the ability to participate without revealing personal information, but this anonymity also protects scammers. Some projects now offer tiered systems where basic functions remain open to all, while advanced features require verification. This approach tries to keep the system accessible while adding security where it matters most, showing how creative solutions can partially resolve these conflicts (Zhou et al., 2024).

Technical solutions also face this balance challenge. Features like transaction reversals or admin controls could stop many attacks, but they introduce central points of failure. Fully decentralized systems cannot take back transactions or change smart contracts once deployed, which makes them secure against censorship but vulnerable to irreversible hacks. The development of decentralized security tools, like community-operated monitoring systems, represents an attempt to get security benefits without centralized control. These examples demonstrate how the DeFi community continues to search for ways to protect users while staying true to blockchain's original vision (Babel et al., 2023).

The future of DeFi will likely involve ongoing negotiation between these competing priorities. Different projects may choose different balances based on their specific purposes and user needs. What remains clear is that neither complete decentralization nor complete security is practical alone - the most successful systems will find ways to blend both qualities. As the technology matures, new solutions may emerge that reduce these trade-offs, but for now, understanding and managing them remains essential for anyone involved in decentralized finance. The discussion about where to draw these lines will continue shaping DeFi's evolution as it grows from an experimental technology into a more mature financial system (M. N. M. Bhutta et al., 2021).

6.2. Future Trends in DeFi Security

As decentralized finance continues to evolve, new approaches to security are emerging that could significantly change how DeFi platforms protect user funds. The rapid development of blockchain technology suggests that future security solutions will need to adapt to increasingly sophisticated threats while maintaining the core principles of decentralization (Alamsyah and Salsabila, 2024).

Several key trends are likely to shape the next generation of DeFi security measures, offering both challenges and opportunities for the ecosystem.

One important trend is the development of more advanced smart contract monitoring systems. Future platforms may use artificial intelligence to detect suspicious transactions in real time, potentially stopping attacks before they happen (Xia et al., 2023). These systems could analyze patterns across multiple blockchains to identify new types of exploits as they emerge. At the same time, decentralized oracle networks are becoming more robust, reducing the risk of price manipulation attacks that have caused major losses in the past (Babel et al., 2023). These technological improvements aim to create safer environments without relying on centralized authorities.

Another growing area is the use of decentralized insurance solutions to protect against potential losses. Rather than depending on traditional insurance companies, these systems allow users to pool risk across the community (Shelke et al., 2024). Smart contracts could automatically trigger payouts when certain attack patterns are detected, providing faster compensation for victims. This approach combines financial protection with the transparency of blockchain technology. Alongside insurance, better recovery mechanisms may develop, such as community-approved methods to reverse clearly fraudulent transactions while preserving the ability to challenge questionable cases (Zhou et al., 2024).

The relationship between regulation and DeFi security will also continue to develop. While complete government control contradicts decentralization, some form of standardized security practices could emerge through industry cooperation (Sriman and Kumar, 2022). Future frameworks might establish basic security requirements that projects can meet in decentralized ways, such as through community audits or transparent governance processes. Education will play an increasingly important role as well, with more resources available to help users identify risks and understand security best practices (Li et al., 2022).

Looking ahead, the most successful security solutions will likely be those that maintain DeFi's open nature while providing stronger protections (M. N. M. Bhutta et al., 2021). The future may see hybrid systems that combine automated security tools with human oversight in decentralized ways. As attackers develop new methods, the DeFi community's ability to adapt quickly while

staying true to its principles will determine whether decentralized finance can achieve both security and freedom at scale. The coming years will test whether these competing priorities can be balanced effectively as the technology moves toward mainstream adoption.

7. Conclusion

7.1. Answers to the Research Questions

This research explored three main questions about security challenges in decentralized finance (DeFi).

First, technical flaws in DeFi systems, such as smart contract bugs or oracle failures, create significant vulnerabilities (Li et al., 2022). Smart contracts with coding errors allow attackers to steal funds or manipulate systems. Oracle failures, where external data sources provide incorrect information, enable price manipulation attacks (Babel et al., 2023). These technical weaknesses often exist because DeFi projects prioritize speed over security during development, leaving hidden risks in complex code (AlFaw et al., 2022).

Second, current security practices like audits or insurance funds frequently fail because they have limitations (Sujeetha and Deiva Preetha, 2021). Audits cannot catch all vulnerabilities, especially if rushed or done by inexperienced teams. Many projects skip audits entirely to save time or costs. Insurance funds, while helpful, may lack enough money to cover large-scale attacks, leaving users unprotected (Yu et al., 2021). Additionally, human factors like anonymous developers or poor governance decisions reduce the effectiveness of these measures. Users often trust projects without proper checks, assuming audits guarantee safety when they do not (Zhou et al., 2024).

Third, new strategies must address both technical and human risks (M. N. M. Bhutta et al., 2021). For technical improvements, combining automated tools with regular code reviews by independent experts can reduce smart contract flaws (Çulha and Yazici, 2024). Decentralized oracle networks with multiple data sources can prevent manipulation (Wang et al., 2023). For human factors, better education helps users identify risky projects, while requiring developer identity checks (without compromising privacy) increases accountability (Leong et al., 2024). Decentralized organizations should adopt governance models that prevent rushed decisions, such as longer voting periods or community-led security committees (Košťál et al., 2023).

7.2. Summary of Key Findings

This examination of blockchain security in decentralized finance has revealed several important patterns about the current state of DeFi and its vulnerabilities (M. N. M. Bhutta et al., 2021). The research shows that while DeFi offers innovative financial solutions, it faces significant security challenges that threaten its growth and adoption (Sriman and Kumar, 2022). Smart contract exploits, flash loan attacks, and rug pulls continue to cause substantial losses, demonstrating that technical weaknesses combined with malicious intent create serious risks for users (Xia et al., 2023). These security issues stem from both technological limitations and human factors, including complex code, rushed development, and the anonymous nature of many projects (AlFaw et al., 2022).

The analysis of attack methods highlights how different threats require different solutions (Li et al., 2022). Flash loan attacks exploit instant access to large amounts of capital, while rug pulls take advantage of poor project oversight (Zhou et al., 2024). Case studies of real incidents demonstrate how these attacks unfold in practice, showing common patterns that could help identify future threats (Babel et al., 2023). Technical solutions like smart contract audits, time locks, and token vesting provide partial protection, but no single measure can prevent all possible attacks (Sujeetha and Deiva Preetha, 2021). The trade-offs between security and decentralization remain challenging, as stricter protections often require sacrificing some aspects of the permissionless, open nature that makes DeFi unique (Košťál et al., 2023).

Looking forward, the future of DeFi security will likely involve a combination of technological improvements, better education, and balanced regulation (Wang et al., 2023). Advanced monitoring systems, decentralized insurance, and community-based security measures could help reduce risks while preserving core blockchain principles (Shelke et al., 2024). The findings suggest that achieving both strong security and true decentralization is difficult but not impossible, requiring ongoing innovation and cooperation across the ecosystem (Alamsyah and Salsabila, 2024). As DeFi continues to develop, addressing these security challenges will be essential for building trust and enabling wider adoption of decentralized financial systems (Leong et al., 2024). The lessons from this research provide a foundation for understanding current risks and developing more robust solutions to protect users and ensure the long-term success of decentralized finance.

References

Abuhashim, A., & Tan, C. C. (2020). Smart contract designs on blockchain applications. 2020 IEEE Symposium on Computers and Communications (ISCC) (pp. 1–4). <https://doi.org/10.1109/ISCC50000.2020.9219622>

Alamsyah, A., & Salsabila, N. (2024). Exploring the mechanisms of decentralized finance (DeFi) using blockchain technology. 2024 3rd International Conference on Creative Communication and Innovative Technology (ICCIT) (pp. 1–8). <https://doi.org/10.1109/ICCIT62134.2024.10701148>

AlFaw, A., Elmedany, W., & Sharif, M. S. (2022). Blockchain vulnerabilities and recent security challenges: A review paper. 2022 International Conference on Data Analytics for Business and Industry (ICDABI) (pp. 780–786). <https://doi.org/10.1109/ICDABI56818.2022.10041611>

Babel, K., Daian, P., Kelkar, M., & Juels, A. (2023). Clockwork finance: Automated analysis of economic security in smart contracts. 2023 IEEE Symposium on Security and Privacy (SP) (pp. 2499–2516). <https://doi.org/10.1109/SP46215.2023.10179346>

Bhutta, M. N. M., et al. (2021). A survey on blockchain technology: Evolution, architecture and security. IEEE Access, 9, 61048–61073. <https://doi.org/10.1109/ACCESS.2021.3072849>

Busayatananphon, C., & Boonchieng, E. (2022). Financial technology DeFi protocol: A review. 2022 Joint International Conference on Digital Arts, Media and Technology with ECTI Northern Section Conference on Electrical, Electronics, Computer and Telecommunications Engineering (ECTI DAMT & NCON) (pp. 267–272). <https://doi.org/10.1109/ECTIDAMTNCON53731.2022.9720373>

Çulha, D., & Yazici, A. (2024). Smart contract upgradability: A structured and natural approach. 2024 6th International Conference on Blockchain Computing and Applications (BCCA) (pp. 198–203). <https://doi.org/10.1109/BCCA62388.2024.10844407>

Košťál, K., Bahar, M. N., Gazdík, R., & Ries, M. (2023). Advancing decentralized finance: A comprehensive pool-based liquidity protocol. 2023 Fifth International Conference on Blockchain

Computing and Applications (BCCA) (pp. 158–165). <https://doi.org/10.1109/BCCA58897.2023.10338926>

Leong, W. Y., Leong, Y. Z., & Leong, W. S. (2024). Enhancing blockchain security. 2024 IEEE Symposium on Wireless Technology & Applications (ISWTA) (pp. 108–112). <https://doi.org/10.1109/ISWTA62130.2024.10651753>

Li, W., Bu, J., Li, X., & Chen, X. (2022). Security analysis of DeFi: Vulnerabilities, attacks and advances. 2022 IEEE International Conference on Blockchain (Blockchain) (pp. 488–493). <https://doi.org/10.1109/Blockchain55522.2022.00075>

Shelke, P., Wawage, P., Sable, N., Dedgaonkar, S., Jagdale, M., & Kulkarni, P. (2024). Transforming insurance processes with ICP blockchain integration. 2024 IEEE Pune Section International Conference (PuneCon) (pp. 1–5). <https://doi.org/10.1109/PuneCon63413.2024.10895511>

Sriman, B., & Kumar, S. G. (2022). Decentralized finance (DeFi): The future of finance and DeFi application for Ethereum blockchain based finance market. 2022 International Conference on Advances in Computing, Communication and Applied Informatics (ACCAI) (pp. 1–9). <https://doi.org/10.1109/ACCAI53970.2022.9752657>

Sujeetha, R., & Deiva Preetha, C. A. S. (2021). A literature survey on smart contract testing and analysis for smart contract based blockchain application development. 2021 2nd International Conference on Smart Electronics and Communication (ICOSEC) (pp. 378–385). <https://doi.org/10.1109/ICOSEC51865.2021.9591750>

Wang, Z., Lu, H., & Wei, X. (2023). Ethereum DeFi apps in the wild: Profiling and Implications. 2023 IEEE International Conference on Metaverse Computing, Networking and Applications (MetaCom) (pp. 388–392). <https://doi.org/10.1109/MetaCom57706.2023.00074>

Xia, Q., et al. (2023). Detecting flash loan based attacks in Ethereum. 2023 IEEE 43rd International Conference on Distributed Computing Systems (ICDCS) (pp. 154–165). <https://doi.org/10.1109/ICDCS57875.2023.00078>

Yu, T.-W., Wang, A.-P., Tseng, L.-M., & Tsao, W.-M. (2021). A preliminary study of the impact of blockchain technology on the application level of insurance industry. 2021 IEEE International Conference on Social Sciences and Intelligent Management (SSIM) (pp. 1–5). <https://doi.org/10.1109/SSIM49526.2021.9555203>

Zhou, Y., Sun, J., Ma, F., Chen, Y., Yan, Z., & Jiang, Y. (2024). Stop pulling my rug: Exposing rug pull risks in crypto token to investors. *2024 IEEE/ACM 46th International Conference on Software Engineering: Software Engineering in Practice (ICSE-SEIP)* (pp. 228–239). <https://doi.org/10.1145/3639477.3639722>